

ISO/IEC 27001:2022 — Overview for Practitioners

Original educational overview written for the sovereign-rag demo corpus. ISO/IEC 27001:2022 itself is a copyrighted standard published by ISO and IEC; nothing below reproduces its text. This document explains publicly known concepts in its authors' own words.

Date: 2026-07-13

What ISO/IEC 27001 is

ISO/IEC 27001:2022 is the international standard that defines the requirements for establishing, implementing, maintaining and continually improving an Information Security Management System (ISMS). Certification against it is the most widely recognised way for an organisation to demonstrate that it manages information security systematically rather than through ad-hoc technical fixes. The 2022 edition replaced the 2013 edition; organisations certified under the older edition had a transition period that ended on 31 October 2025.

The ISMS: a management loop, not a checklist

The heart of the standard is not a list of security products but a management loop. An organisation must define the scope of its ISMS (which parts of the business, which sites, which services), understand its internal and external context, identify interested parties — customers, regulators, employees — and their requirements, and secure visible commitment from top management. Security objectives must be measurable and reviewed. Internal audits, management reviews and corrective actions close the loop: the ISMS is expected to improve continually, in the spirit of Plan-Do-Check-Act.

Risk assessment and risk treatment

ISO/IEC 27001 is fundamentally risk-driven. The organisation defines a repeatable method for identifying information security risks, analysing their likelihood and impact, and evaluating them against acceptance criteria. For every unacceptable risk, a treatment option is chosen: mitigate it with controls, transfer it (insurance, outsourcing), avoid the risky activity, or accept the residual risk explicitly. Two artefacts anchor the process: the risk treatment plan, and the Statement of Applicability (SoA), which lists every reference control, states whether it applies, and justifies inclusions and exclusions. Auditors read the SoA first: it is the map between the organisation's risks and its actual safeguards.

Annex A: 93 controls in four themes

The 2022 revision reorganised the reference controls from fourteen domains into 93 controls grouped into four themes:

- Organizational controls (37): policies, roles and responsibilities, supplier relationships, cloud service security, threat intelligence, incident management, legal and regulatory compliance.
- People controls (8): screening, terms of employment, awareness and training, disciplinary process, responsibilities after termination.

- Physical controls (14): secure areas, physical entry, protection against environmental threats, equipment maintenance, clear desk and clear screen.
- Technological controls (34): access control and authentication, cryptography, logging and monitoring, vulnerability management, backup, secure development, data masking, data leakage prevention, web filtering.

Eleven controls were introduced in 2022 — among them threat intelligence, information security for the use of cloud services, ICT readiness for business continuity, configuration management, information deletion, data masking, data leakage prevention, monitoring activities, web filtering, secure coding and physical security monitoring — reflecting a decade of change in how systems are built and attacked.

Certification lifecycle

Certification is performed by an accredited certification body in two stages: a documentation review (Stage 1), then an implementation audit (Stage 2). A certificate is valid for three years, with surveillance audits at least annually and a full recertification audit at the end of the cycle. Nonconformities must be addressed through documented corrective actions.

Why it matters alongside Swiss data protection law

For Swiss organisations, ISO/IEC 27001 and data protection law reinforce each other. Article 8 of the revised Federal Act on Data Protection (FADP / nLPD) requires controllers and processors to ensure a level of data security adequate to the risk, through appropriate technical and organisational measures — exactly what an ISMS operationalises. Cantonal public-sector rules such as Geneva's LIPAD carry similar obligations for public institutions. An ISMS does not replace legal compliance, but it provides the documented, auditable structure — risk register, Statement of Applicability, incident process, supplier controls — that makes compliance demonstrable to authorities, auditors and customers.